

Cyber Attacks – Exam Preparation Summary

Covers: Common Cyber Attacks • Malware Definitions • IoT Security • eCommerce Security • Protocols & Standards

1. DoS & DDoS Attacks

DoS: Overwhelms a system so it cannot respond – single machine.

DDoS: Same, but launched from *many* compromised hosts (botnet).

Note: DoS does not give direct benefit to attacker; may be used to take system offline before another attack (e.g., session hijacking).

Sub-types

- **TCP SYN Flood:** Floods half-open connection queue; target times out. *Fix:* Firewall blocking inbound SYN; larger queues.
- **Teardrop:** Overlapping IP fragment offsets crash target. *Fix:* Disable SMBv2; block ports 139 & 445.
- **Smurf:** IP spoofing + ICMP broadcast saturates network. *Fix:* Disable IP-directed broadcasts at routers.
- **Ping of Death:** IP packet > 65,535 bytes → buffer overflow. *Fix:* Firewall checks fragmented IP size.
- **Botnets:** Millions of malware-infected machines used for DDoS. *Fix:* RFC3704 + Black hole filtering (via BGP).

2. Man-in-the-Middle (MitM)

Hacker inserts itself **between** client-server communications to intercept/alter data.

Sub-types

- **Session Hijacking:** Takes over authenticated session by replacing client's IP & spoofing sequence numbers.
- **IP Spoofing:** Sends packets with trusted IP to gain access. Also used in DoS to route responses to victim's spoofed IP. Also called *IP address forgery* or *host file hijack*.
- **Replay Attack:** Re-sends intercepted old messages. *Fix:* Nonces / session timestamps.
- **DNS/HTTPS/ARP/SSL Spoofing, Wi-Fi Hacking.**

Defense: Encryption + Digital Certificates; Certificate Authorities + Hash functions. Modern routers/firewalls protect against IP spoofing.

Secure message flow (P2 → P):

1. P2 creates symmetric key, encrypts with P's public key.
2. P2 sends encrypted symmetric key to P.
3. P2 hashes message & digitally signs it.
4. P2 encrypts message + signed hash with symmetric key, sends to P.
5. P decrypts using private key → gets symmetric key.
6. P decrypts message + verifies hash integrity & sender authenticity.

3. Phishing & Spear Phishing

Phishing: Fake emails from “trusted” sources to steal info or install malware. Combines social engineering + technical trickery.

Spear Phishing: Highly *targeted* phishing using personal research on victim.

Techniques used: Email spoofing (falsified From field), website cloning (fake copy of real site).

Defense:

- Critical thinking – analyze before clicking
- Hover over links before clicking
- Analyze email headers (Reply-to, Return-Path must match domain)
- Sandboxing email attachments/links

4. Drive-By Attack

Malicious script injected into HTTP/PHP on insecure websites. **No user action needed** – just visiting the page installs malware or redirects to attacker-controlled site.

Defense: Keep OS/browsers updated; minimize browser plugins; avoid suspicious sites.

5. Password Attack

- **Brute-Force:** Random/systematic password guessing (name, job, hobbies etc.).
- **Dictionary Attack:** Compares encrypted dictionary of common passwords to stolen hash.

Other methods: Desk snooping, sniffing network, social engineering, DB access.

Defense: Account lockout policy after n failed attempts.

6. SQL Injection

Malicious SQL commands inserted into input fields to manipulate DB queries. Common in PHP, ASP apps with dynamic SQL.

Example: Input ' or '1'='1' → query returns ALL records.

Risks: Read sensitive data, modify/delete data, execute admin operations.

Defense:

- Least-privilege DB permissions
- Stored procedures + parameterized queries (no dynamic SQL)
- Whitelist input validation at application level

7. Cross-Site Scripting (XSS)

Attacker injects malicious JavaScript into a website's database. Victim's browser executes it on page load. Primarily abuses JavaScript.

Consequences: Cookie theft → session hijacking; keystroke logging; screenshots; remote machine control.

Defense: Sanitize/escape inputs; encode <, >, &, /, ? to HTML/URL equivalents; disable client-side scripts.

8. Eavesdropping Attack

Also known as **sniffing** or **snooping** attack. Intercepts network communications. **Difficult to detect** – no abnormality in network transmissions.

- **Passive:** Silently listens to network traffic (listening/monitoring).
- **Active:** Disguises as friendly unit; probes/scans/tampers (queries transmitters).

Note: Detecting passive eavesdropping is critical since active attacks build on passive info first.

Defense: Data Encryption (best countermeasure).

9. Birthday Attack

Targets **hash functions**. Finds two different messages with the **same hash digest (MD)** (collision) → replaces original message with attacker's. Receiver cannot detect substitution since MDs match.

Based on Birthday Paradox in probability. A hash function produces a fixed-length MD regardless of input length.

10. Malware Attack

Type	Key Characteristic
Macro Virus	Infects MS Word/Excel; runs on app open
File Infector	Attaches to .exe files; runs on load
Boot-Record	Infects master boot record; loads at startup
Polymorphic	Varies encryption to evade detection; high entropy
Stealth Virus	Compromises AV software to hide itself
Trojan	Hides in useful programs; no self-replication ; opens back doors
Logic Bomb	Triggers on specific condition/date-time
Worm	Self-contained ; propagates across networks without host file
Dropper	Installs viruses; often not detected by AV scanners
Ransomware	Encrypts files; demands ransom (Bitcoin); cryptoviral extortion
Scareware	<i>Fake</i> ransomware; uses browser redirect tricks; easily disabled
Adware	Redirects browser to ads; piggybacks on free software
Spyware	Tracks activity secretly; sends to 3rd party
Keylogger	<i>Type of spyware</i> ; records every keystroke (steals passwords)
Rootkit	Gives remote admin (root) access ; hides own presence

11. Trapdoor (Backdoor)

NEW – A **secret entry point** into a program allowing access *without normal security procedures* (e.g., no password needed). Used legitimately by developers for debugging; exploited by hackers.

- Hackers insert trapdoors after successful penetration for *later re-entry*, even if original vulnerability is closed.
- Developers may accidentally leave debug trapdoors in released software.
- **Fix:** Focus security on *program development* and *software update activities*; OS controls are difficult to apply.

12. Rootkit

Collection of tools giving **remote admin-level (root) access**. Hides inside legitimate software using its power to **conceal its own presence**. Includes keyloggers, password stealers, AV disablers.

Spread via: Phishing emails, malicious links, suspicious software downloads.

13. IoT Security Services

1. **Authentication:** Confirm and ensure identity of IoT objects.
2. **Authorization:** Grant permissions to entities.
3. **Integrity:** Maintain consistency/accuracy of data throughout lifecycle.

4. **Confidentiality:** Only authorized people access data.
5. **Non-repudiation:** Cannot deny that an action/data transfer occurred.
6. **Availability:** Service available anywhere, anytime.
7. **Privacy:** No unauthorized access to private data.

14. IoT Layer Security (3-Layer)

Perception Layer Attacks

- **Node Capture:** Controls nodes to clone/redistribute malicious ones.
- **DoS:** Overwhelms system with spam requests.
- **Denial of Sleep:** Drains node battery preventing sleep mode.
- **DDoS (Mirai Oct 2016):** Large-scale using IoT nodes as bots.
- **Fake Node / Sybil:** Fake identities → wrong data / energy drain.
- **Replay:** Stored data re-transmitted without authorization.
- **Routing Threats:** Creates routing loops, delays, errors.
- **Side-Channel:** Exploits hardware (power, timing, EM) to find crypto keys.
- **Mass Node Auth:** Authenticating huge device counts overloads network.

Requirements: Lightweight encryption, authentication, key agreement, data confidentiality.

Network Layer Attacks

- **MitM / MITB:** Intercepts & spoofs both communication ends.
- **DoS:** Jamming radio signals using fake nodes.
- **Eavesdropping/Sniffing:** Passive interception of credentials/config.
- **Black Hole:** Fake node claims shortest path; drops ALL packets.
- **Gray Hole:** Like black hole but drops only *selected* packets.
- **Worm Hole:** Tunnel between two network points; replays data.
- **Hello Flood:** Broadcasts Hello packets to waste node energy/create traffic.
- **Sybil:** Multiple fake identities from one node → dominates network.

Requirements: Hop-to-hop encryption, point-to-point authentication, key management, secure routing, intrusion detection.

Application Layer Issues

- **Data Access & Auth:** Many users → complex permission/access control.
- **Data Privacy & Identity:** Different manufacturers → conflicting auth schemes.
- **Big Data Availability:** Massive IoT data → overhead on application.

Requirements: Authentication, privacy protection, information security management.

Layer	Security Requirements
Perception	Lightweight Encryption, Authentication, Key Agreement, Data Confidentiality
Network	Communication Security, Routing Security, Authentication, Key Management, Intrusion Detection
Application	Authentication, Privacy Protection, Info Security Management

15. eCommerce Security

NEW – Principles that guide safe electronic transactions over the internet. Customer trust depends on it.

Core eCommerce Security Principles

- **Privacy/Confidentiality:** Info not shared with unauthorized parties; not intercepted in transit.
- **Integrity:** Information not altered during network transmission.
- **Availability:** Info available wherever/whenever required within specified time.
- **Authenticity:** Mechanism to authenticate user before granting access.
- **Non-Repudiability:** Sender cannot deny sending; recipient cannot deny receiving.
- **Encryption:** Info encrypted/decrypted only by authorized user.
- **Auditability:** Data recorded to allow integrity auditing.

Security Measures

- **Encryption:** Sender encrypts with secret code; only specified receiver decrypts.
- **Digital Signature:** Ensures authenticity via encryption + password; e-signature.
- **Security Certificates:** Unique digital ID to verify identity of website/user.

Security Protocols

- **SSL (Secure Socket Layer):** Most widely used protocol. Provides Authentication, Encryption, Integrity, Non-repudiation. Uses `https://` prefix.
- **TLS (Transport Layer Security):** Authenticates and encrypts links between networked computers. SSL certificate enables HTTP → HTTPS transition.
- **SHTTP (Secure HTTP):** Extends HTTP with public key encryption, authentication, digital signature. Negotiates encryption scheme between client and server.
- **SET (Secure Electronic Transaction):** Developed by MasterCard & Visa. Theoretically the best protocol. Components:
 - Card Holder's Digital Wallet Software
 - Merchant Software
 - Payment Gateway Server Software
 - Certificate Authority Software

Authentication Methods

- **2SV (2-Step Verification):** One-time code via email/SMS/call.
- **2FA (2-Factor Auth):** Requires acknowledgment through another device/app.
- **MFA (Multi-Factor Auth):** Like 2FA but can use more than two factors.

Standards & Compliance

- **PCI DSS:** Ensures credit card info is transmitted/stored securely online.
- **ISO/IEC 27001:2013:** International standard for data security management systems, risk-aversion, and standardized business practices.
- **Personal Data:** Any data linkable to a specific individual (names, emails, phone numbers, or even anonymized datasets that identify a person). Protected under GDPR.

Malware Definitions (Precise)

NEW – Key definitional distinctions for exam.

- **Virus:** Inserts itself into another program's code; forces it to spread. Transmitted via email attachments, downloads, diskettes.
- **Worm:** *Standalone*, self-replicating; does NOT alter files; noticed when resource consumption slows the system.
- **Trojan:** Cannot reproduce itself; *masquerades* as something useful; tricks user into activating it.
- **Spyware:** Secretly gathers data; sends to third party; monitors location, captures credit card numbers. *Keylogger* is a specific type.
- **Rootkit:** Kit of tools for *root (admin) access*; hides its own presence from detection.

- **Adware:** Forces browser to redirect to ads; often bundled with free games/extensions.
- **Ransomware:** Encrypts hard drive; demands Bitcoin ransom. *Without decryption key, mathematically impossible to recover files.*
- **Logic Bomb:** Delayed-action virus; “explodes” at a set time or condition; can delete/corrupt data.
- **Trapdoor:** Secret entry point; bypasses normal security; used in debugging but exploited by hackers.

Key Differences:

- Worm vs Virus: Worm is *standalone*; Virus *needs a host program*.
- Trojan vs Virus: Trojan does *not self-replicate*; Virus does.
- Ransomware vs Scareware: Ransomware *actually encrypts* files; Scareware only *claims* to.

Quick Countermeasures Cheat Sheet

- Keep systems & antivirus **up to date**
- **Strong passwords** + account lockout policies
- Use **encryption** (SSL/TLS) for all communications
- **Firewall** rules (whitelist only needed ports/hosts)
- **Least-privilege** model in IT environment
- Regular **backups** of all critical data
- **Employee training** on social engineering & phishing
- Continuously **audit** IT systems for anomalies
- Use **certificate authorities** to verify public keys
- **Parameterized queries** for all database operations
- Use **MFA/2FA** for all sensitive accounts
- Focus security on **program development** to prevent trapdoors
- Comply with **PCI DSS & ISO 27001** for eCommerce